

UD1 - Prácticas: introducción a la seguridad

Preparación de un entorno de laboratorio Linux y elaboración de un plan básico de gestión de riesgos.

Datos de las prácticas	Información
Módulo	Seguridad y Alta Disponibilidad
Curso	2.º ASIR
Modalidad	Semipresencial
Duración estimada	6 horas
Entorno	VirtualBox y una distribución Linux compatible

1. Objetivos

Al finalizar las prácticas, el alumnado será capaz de:

- Preparar una máquina virtual aislada para prácticas de seguridad.
- Identificar activos, amenazas, vulnerabilidades y riesgos.
- Aplicar medidas básicas de protección en un sistema Linux.
- Proponer controles técnicos, organizativos y físicos proporcionados.
- Documentar evidencias y un plan de mejora realista.

2. Alcance y normas del laboratorio

- Trabaja únicamente sobre tu propia máquina virtual y los sistemas autorizados por el profesorado.
- No realices análisis, escaneos ni pruebas sobre equipos, redes o servicios ajenos.
- No uses datos personales reales en capturas, informes ni pruebas.
- Realiza una snapshot antes de cambiar configuraciones relevantes para poder volver a un estado conocido.

3. Preparación común

3.1. Material necesario

- Un equipo con virtualización habilitada.
- [VirtualBox](#).
- Una ISO de instalación mínima de una distribución Linux compatible.
- Espacio libre en disco para la máquina virtual.

AlmaLinux es la distribución recomendada para mantener la continuidad con el resto del módulo, pero no es obligatoria. También se pueden utilizar Debian, Ubuntu Server, Rocky Linux o Fedora. En este documento, los comandos se muestran para AlmaLinux y distribuciones de la familia RHEL; en Debian o Ubuntu se debe usar `apt` en lugar de `dnf`.

3.2. Crear la máquina virtual

1. Instala VirtualBox desde su sitio oficial y ábrelo.
2. Selecciona **Nueva** y asigna el nombre `linux-ud01`.
3. Selecciona la ISO descargada. Si VirtualBox propone una instalación desatendida, desmárcala para completar manualmente las opciones de instalación.
4. Asigna como referencia 2 GB de memoria RAM, 2 procesadores y un disco virtual dinámico de 25 GB. Ajusta estos valores si el equipo anfitrión dispone de pocos recursos.
5. En la configuración de red, selecciona **NAT**. Esta opción permite actualizar el sistema sin exponer directamente la máquina virtual a la red local.
6. Inicia la máquina y sigue el asistente de instalación de la distribución elegida.

3.3. Instalar y configurar el sistema

1. Elige el idioma de instalación.
2. En **Destino de la instalación**, selecciona el disco virtual creado y acepta la configuración automática de particiones.
3. Activa la conexión de red y establece el nombre de equipo `linux-ud01`.
4. Crea una cuenta de usuario con la inicial de tu nombre seguida de tu primer apellido. Ejemplo: `fperez`.
5. Marca la opción para que el usuario pueda administrar el sistema y crea una contraseña robusta para la cuenta administrativa.
6. Inicia la instalación. Cuando termine, reinicia la máquina y retira la ISO virtual si se solicita.
7. Inicia sesión con el usuario creado y abre una terminal.

3.4. Comprobaciones iniciales

Ejecuta estos comandos y guarda una captura o copia de la salida de cada uno:

```
hostnamectl  
cat /etc/os-release  
ip a  
whoami
```

Actualiza el sistema. Introduce la contraseña cuando se solicite:

```
# AlmaLinux, Rocky Linux o Fedora  
sudo dnf update -y  
  
# Debian o Ubuntu  
sudo apt update && sudo apt upgrade -y
```

Comprueba que el usuario pertenece al grupo de administración:

```
id  
sudo -l
```

Explica brevemente qué evidencia aporta cada comando: identidad del sistema, versión, configuración de red e identidad/permisos del usuario.

3.5. Crear una snapshot

1. Apaga la máquina virtual desde Linux o asegúrate de que queda en un estado consistente.
2. En VirtualBox, selecciona **linux-ud01** y abre la vista **Snapshots**.
3. Crea una instantánea denominada **01-instalacion-actualizada**.
4. Añade una descripción que indique la fecha y que el sistema ha sido actualizado.
5. Incluye una captura de la snapshot en la entrega.

La snapshot permite recuperar rápidamente el estado inicial del laboratorio. No sustituye a una copia de seguridad externa, pero reduce el riesgo de perder tiempo ante una configuración errónea durante las prácticas posteriores.

4. Práctica 1 - Revisión básica de seguridad del sistema

4.1. Inventario mínimo

1. Crea una carpeta para las evidencias de la práctica:

```
mkdir -p ~/ud01/evidencias
```

2. Guarda en un fichero la información básica del equipo:

```
hostnamectl > ~/ud01/evidencias/sistema.txt  
ip a >> ~/ud01/evidencias/sistema.txt
```

3. Revisa los servicios actualmente activos:

```
systemctl list-units --type=service --state=running
```

4. Identifica tres activos de tu laboratorio: la máquina virtual, la cuenta de usuario y la configuración de red. Indica para cada uno qué información o servicio protege y por qué tiene valor.

4.2. Cuentas y mínimo privilegio

1. Consulta las cuentas locales del sistema:

```
getent passwd
```

2. Distingue entre la cuenta creada durante la instalación y las cuentas de servicio. No elimines cuentas del sistema.

3. Crea una cuenta de prueba sin permisos administrativos:

```
sudo useradd -m invitado_ud01
sudo passwd invitado_ud01
```

4. Comprueba que la cuenta no puede ejecutar órdenes administrativas:

```
su - invitado_ud01
sudo -l
exit
```

5. Explica cómo este resultado aplica el principio de mínimo privilegio.

6. Elimina la cuenta de prueba al finalizar:

```
sudo userdel -r invitado_ud01
```

4.3. Actualizaciones y registros

1. Comprueba las actualizaciones pendientes:

```
sudo dnf check-update
```

Es normal que este comando indique que no hay actualizaciones o devuelva un código distinto de cero cuando existen paquetes pendientes.

2. Consulta los últimos eventos del sistema:

```
sudo journalctl -n 30
```

3. Describe dos ejemplos de información que un registro puede aportar durante una investigación: fecha y hora de un reinicio, servicio que generó un error, cuenta que inició sesión o cambios realizados por el administrador.

5. Práctica 2 - Plan de gestión de riesgos

5.1. Seleccionar un escenario

Elige uno de estos escenarios para el informe:

Escenario	Organización	Situación principal
A	TechSolutions S.L.	Migración a la nube, CMS y accesos sospechosos a documentación técnica.
B	PetCare SL	Historiales digitalizados, servidor externo y datos corruptos o expuestos.
C	GourmetExpress	Pedidos y pagos en línea, servidor en un almacén y caídas del servicio.
D	CulturaUrbana	Plataforma de eventos, redes sociales comprometidas y corte eléctrico en el servidor.
E	Venus SA	Digitalización de historiales, CMS y servidor en un espacio inadecuado.

5.2. Paso 1: inventario y clasificación de activos

1. Identifica al menos ocho activos del escenario, incluyendo información, personas, servicios, hardware, software y comunicaciones.
2. Clasifica cada activo según su importancia: alta, media o baja.
3. Relaciona cada activo con una propiedad de seguridad prioritaria: confidencialidad, integridad o disponibilidad.
4. Completa una tabla como esta:

Activo	Tipo	Valor	Propiedad prioritaria	Justificación
Base de datos de clientes	Información	Alto	Confidencialidad	Contiene datos personales y es necesaria para el servicio.

5.3. Paso 2: amenazas y vulnerabilidades

1. Para al menos cinco activos, identifica una amenaza posible y una vulnerabilidad que podría facilitar el incidente.
2. Incluye amenazas técnicas, humanas y físicas.
3. Distingue claramente amenaza y vulnerabilidad. Por ejemplo, el ransomware es una amenaza; un sistema sin actualizar es una vulnerabilidad.
4. Completa la tabla:

Activo	Amenaza	Vulnerabilidad	Posible incidente	Evidencia del escenario
Servidor web	Acceso no autorizado	CMS sin actualizar	Robo o alteración de datos	La organización usa un CMS de código abierto.

5.4. Paso 3: valorar los riesgos

1. Estima la probabilidad y el impacto de cada caso como bajo, medio o alto.
2. Calcula un nivel de riesgo utilizando esta regla sencilla:

$$\text{Riesgo} = \text{Probabilidad} \times \text{Impacto}$$

3. Puedes usar la siguiente matriz orientativa:

Probabilidad / impacto	Bajo	Medio	Alto
Baja	Bajo	Bajo	Medio
Media	Bajo	Medio	Alto
Alta	Medio	Alto	Muy alto

4. Ordena los riesgos desde el más prioritario hasta el menos prioritario y justifica las tres primeras prioridades.

5.5. Paso 4: plan de mejora

1. Propón al menos seis medidas, combinando controles técnicos, organizativos y físicos.
2. Para cada medida, indica qué riesgo reduce y qué principio de seguridad protege.
3. Prioriza medidas realistas para una organización pequeña: MFA en cuentas administrativas, actualizaciones, copias de seguridad verificadas, formación ante phishing, revisión de permisos, cifrado de portátiles, SAI o reubicación de equipos.
4. Completa la tabla:

Riesgo priorizado	Medida propuesta	Tipo de control	Responsable	Prioridad	Evidencia de aplicación
Robo de credenciales	MFA y formación ante phishing	Técnico y organizativo	Administración de sistemas	Alta	Captura de la configuración y registro de la formación.

5.6. Paso 5: respuesta ante un incidente

Redacta un procedimiento de una página para uno de los riesgos altos. Debe incluir:

1. Detección: qué alerta o indicio permite reconocer el incidente.
2. Análisis: qué datos se revisarán y quién los revisará.
3. Contención: cómo limitar el daño sin destruir evidencias.
4. Erradicación y recuperación: cómo eliminar la causa y restaurar el servicio.
5. Lecciones aprendidas: qué medida evitaría o reduciría un incidente similar.

6. Actividades

1. Explica la diferencia entre amenaza, vulnerabilidad, riesgo, ataque e incidente.
2. Clasifica RAID, firewall, SAI, antivirus, copia de seguridad, control de acceso físico e IDS como medidas físicas, lógicas, activas o pasivas.
3. Analiza los problemas de seguridad de la contraseña **empresa2026** y propón una política adecuada.
4. Analiza un correo sospechoso e identifica al menos cinco indicadores de phishing.
5. Realiza el [Ejercicio 2.1: análisis de amenazas](#) e identifica activos, amenazas, vulnerabilidades y medidas de protección.

6. Para un servicio web de laboratorio, describe una actividad autorizada de Red Team, las evidencias que revisaría Blue Team, una mejora de Purple Team y dos reglas de alcance de White Team.
7. Una academia conserva datos de contacto y calificaciones. Propón tres controles técnicos, tres organizativos y un marco de referencia para su mejora continua.

7. Autoevaluación

1. ¿Qué tres propiedades forman la triada CIA?
2. ¿Qué diferencia existe entre amenaza y vulnerabilidad?
3. ¿Qué objetivo tiene la confidencialidad?
4. ¿Qué mecanismo permite comprobar la integridad de un fichero?
5. ¿Qué es el principio de mínimo privilegio?
6. ¿Qué diferencia existe entre seguridad activa y pasiva?
7. ¿Qué significa CVE?
8. ¿Qué es un ataque DDoS?
9. ¿Qué objetivo tiene una auditoría de seguridad?
10. ¿Cuáles son las fases principales de gestión de un incidente?
11. ¿Qué diferencia existe entre Red Team, Blue Team y Purple Team?
12. ¿Qué organismo puede apoyar a una empresa española ante un incidente de ciberseguridad?
13. ¿Qué representa una CVE y para qué sirve CVSS?
14. ¿Qué norma define requisitos certificables para un SGSI?

8. Tarea evaluable única - Análisis de seguridad

Entrega un informe en PDF o Markdown sobre uno de los escenarios de la práctica 2. Debe incluir el inventario de activos, amenazas, vulnerabilidades, valoración de riesgos, seis medidas priorizadas y un procedimiento de respuesta ante uno de los riesgos altos. Añade una política básica de contraseñas, una política de copias de seguridad y una conclusión con las tres medidas más urgentes.

9. Recursos

- [AlmaLinux](#)
- [VirtualBox](#)
- [INCIBE: Plan Director de Seguridad](#)
- [MAGERIT v3](#)
- [ISO/IEC 27001 e ISO/IEC 27002](#)